

03 — Secure Compute, Storage, and Databases (20–25%)

Official subsections:

1. Plan and implement advanced security for compute
 2. Plan and implement security for storage
 3. Plan and implement security for Azure SQL Database and Azure SQL Managed Instance
-

1. Remote access to VMs — Bastion and JIT

Azure Bastion

- Browser-based **RDP/SSH over TLS on port 443**, launched from the Azure portal. The VM needs **no public IP**.
- Deployed **per VNet** into a subnet that must be named exactly **AzureBastionSubnet**, minimum /26.
- The Bastion host itself has a public IP (Standard SKU, static); your VMs do not.
- Protects against **port scanning** and removes the need to expose 3389/22 to the internet.
- **NSG on AzureBastionSubnet** is optional but if present needs specific rules (inbound 443 from Internet, 443 from GatewayManager, 8080/5701 from VirtualNetwork; outbound 3389/22 to VirtualNetwork, 443 to AzureCloud).

SKUs: *Developer* (free, no VNet integration, limited) · *Basic* · **Standard** (adds native client support, IP-based connection, host scaling, shareable links) · **Premium** (adds **session recording** and private-only

deployment). "Must record admin sessions" → **Bastion Premium**.

Just-in-Time (JIT) VM access

- Part of **Defender for Servers Plan 2**.
- Locks down management ports with a **deny** NSG (and Azure Firewall) rule; on request, adds a temporary **allow** rule for a specified source IP for a **maximum requested time** (default 3 hours).
- Configure per port: protocol, allowed source IPs (Per request / CIDR / Any), and max request time.
- User needs write permission on the VM plus
`Microsoft.Security/locations/jitNetworkAccessPolicies/initiate/action`.

Bastion vs JIT: Bastion removes the public IP entirely. JIT keeps the public IP but keeps the port closed until requested. Use both together for defence in depth. If the stem says "no public IP address" → **Bastion**. If it says "temporary, time-limited access with approval and auditing on ports" → **JIT**.

2. Disk encryption — three mechanisms, know which does what

	SSE (platform, default)	Azure Disk Encryption (ADE)	Encryption at host
What	Storage-level encryption of managed disks at rest	BitLocker (Windows) / dm-crypt (Linux) inside the guest OS	Encryption performed on the Azure host before data reaches storage

Always on?	Yes, cannot be disabled	No — opt in	No — opt in, per VM/ VMSS
Keys	PMK by default; CMK via a disk encryption set + Key Vault	CMK in Key Vault — required. Vault needs EnabledForDiskEncryption	PMK or CMK via disk encryption set
Encrypts temp disk	✗ No	✓ Yes (Windows: with the OS volume; Linux: yes)	✓ Yes
Encrypts caches	✗ No	Partially	✓ Yes
Performance cost	None (offloaded)	Uses guest CPU	None — no guest CPU cost
Requires an extension/ agent	No	Yes (AzureDiskEncryption extension)	No

- **Double encryption at rest** = encryption at host (or SSE) with **both** a platform key and a customer-managed key, at the infrastructure level.
- **Disk encryption set** is the object linking a managed disk to a Key Vault key for CMK. It needs a **managed identity** with `get`, `wrapKey`, `unwrapKey` on the vault, and the vault needs **soft delete + purge protection**.
- **Confidential disk encryption** (Confidential VMs, AMD SEV-SNP) — the OS disk is encrypted with a key bound to the VM's **hardware TPM / secure enclave**, so not even the Azure host can read it. The answer for "the cloud provider must not be able to access the data in use".

Exam pattern: "Encrypt the temporary disk and the disk cache with no performance impact on the VM." → **Encryption at host**. "Encrypt the OS volume using BitLocker with keys we control." → **ADE**. "Data

must be protected while in use, even from Microsoft." → **Confidential computing / confidential disk encryption.**

3. Containers — AKS, ACI, ACA, ACR

AKS authentication and authorisation

Four layers, tested as a progression:

1. **Local accounts with Kubernetes RBAC** — the legacy default. Hardening step: **disable local accounts** (`--disable-local-accounts`).
2. **Microsoft Entra integration + Kubernetes RBAC** — Entra identity, permissions defined in Kubernetes `Role/RoleBinding` objects.
3. **Microsoft Entra integration + Azure RBAC for Kubernetes Authorization** — permissions defined as **Azure roles** (`Azure Kubernetes Service RBAC Reader/Writer/Admin/Cluster Admin`). Best for centralised management.
4. **Workload identity** — pods get an Entra identity via **workload identity federation** (this replaced the deprecated pod-managed identity).

`az aks get-credentials` returns admin credentials with `--admin` — the thing to prevent by disabling local accounts.

AKS network isolation

- **Private cluster** — the API server gets a **private IP** and a private endpoint; no public API endpoint. Alternative: **authorized IP ranges** on a public API server.
- **Network policies** — `azure`, `calico`, or `Cilium`. Control **pod-to-pod** traffic. NSGs work on subnets, not pods — pod-level segmentation needs network policies.
- **Egress control** — route egress through **Azure Firewall** with a

UDR; use the `AzureKubernetesService` **FQDN tag** for required outbound endpoints.

- Networking models: **kubenet** vs **Azure CNI** (and CNI Overlay).

Other AKS security

- **Azure Policy for AKS** — uses **Gatekeeper** / **OPA** admission control to audit or **deny** non-compliant pods (e.g. no privileged containers, only approved registries).
- **Defender for Containers** — runtime threat detection, agentless and agent-based vulnerability assessment of images, Kubernetes security posture (KSPM), binary drift detection.
- **Managed identity** for the cluster; **Key Vault provider for Secrets Store CSI Driver** to mount Key Vault secrets into pods.
- Node image auto-upgrade and cluster upgrades for patching.

ACR — Azure Container Registry

- **Authentication:** Entra identity (`az acr login`), **service principal**, **managed identity**, repository-scoped **tokens**, and the **admin account** (disabled by default — keep it disabled).
- **Azure RBAC roles:** `AcrPull`, `AcrPush`, `AcrDelete`, `AcrImageSigner`, plus `Owner/Contributor/Reader`.
- **Premium SKU features:** **private endpoint**, **customer-managed keys**, **content trust** (Docker Notary image signing), **geo-replication**, **repository-scoped tokens**, **quarantine** of newly pushed images until scanned.
- **Disable public network access** and use a private endpoint; **disable anonymous pull**.
- Image scanning by **Defender for Containers** / **MDVM**.

ACI and ACA monitoring

- **Azure Container Instances (ACI)** — deploy into a **VNet subnet** (delegated) for private networking; use **managed identity**; monitor via container **diagnostic logs and metrics** → **Log Analytics** (`ContainerInstanceLog_CL`,

`ContainerEvent_CL`). Defender for Containers covers ACI.

- **Azure Container Apps (ACA)** — deploy into a **VNet** (workload profiles), **internal-only ingress**, **managed identity**, secrets from **Key Vault**, and **Log Analytics** / **Azure Monitor** diagnostic settings for console and system logs.
-

4. Storage account security

Authorisation — three ways, in order of preference

Method	Detail
Microsoft Entra ID (recommended)	Azure RBAC data plane roles: <code>Storage Blob Data Reader</code> / <code>Contributor</code> / <code>Owner</code> , <code>Storage Queue Data ...</code> , <code>Storage File Data SMB Share ...</code> . Supports managed identity, PIM, Conditional Access. Also supports ABAC conditions (e.g. only blobs with a given tag or path prefix).
Shared Access Signature (SAS)	Delegated, time-limited URL token
Shared Key (account keys)	Two 512-bit keys, full control of everything in the account. Cannot be scoped or audited per user.

Hardening actions to memorise:

- `allowSharedKeyAccess = false` → **disable shared key authorisation** entirely, forcing Entra ID. (This also disables account SAS and service SAS, since they are signed with the account key.)
- **Rotate access keys** — rotate `key1`, update apps, rotate `key2`. Store them in **Key Vault** and use **Key Vault managed storage account keys** for automatic rotation (legacy) or, better, move to managed identity.

- **Require secure transfer** (`supportsHttpsTrafficOnly = true`) — HTTPS only.
- **Minimum TLS version = 1.2** (or 1.3).
- `allowBlobPublicAccess = false` — blocks anonymous container/blob access at the account level.
- `publicNetworkAccess = Disabled` — private endpoint only.
- **Infrastructure encryption** — a second layer of 256-bit AES at the infrastructure level (double encryption). **Must be enabled at account creation; cannot be added later.**

SAS types — high-yield

	User delegation SAS	Service SAS	Account SAS
Signed with	Entra ID credentials (a user delegation key)	Storage account key	Storage account key
Scope	Blob and Data Lake Storage Gen2 only	One service (blob, file, queue, table)	Multiple services + account-level operations (create/delete containers)
Max lifetime	7 days	Unbounded (set by you)	Unbounded (set by you)
Revocation	Revoke the user delegation key , or remove RBAC	Stored access policy , or rotate the key	Rotate the account key only
Security	☆ Most secure — Microsoft's recommendation	Medium	Least

- **Stored access policy** — a server-side named policy on a container that a service SAS can reference. It holds start/expiry and permissions, so you can **change or revoke** the SAS without

rotating the account key. **This is the answer to "the SAS must be revocable"**. Limit: **5 stored access policies per container**.

- SAS best practice: **HTTPS only, short expiry, least-privilege permissions, IP address range restriction**, prefer user delegation SAS.
- **SAS expiration policy** on the account can warn/enforce a maximum SAS lifetime.

Azure Files — pick the right access method

Requirement	Answer
Domain-joined VMs in Azure, existing on-prem AD	AD DS authentication over SMB (identity-based, Kerberos)
Cloud-only, no on-prem AD, cloud VMs	Microsoft Entra Domain Services authentication
Entra-joined (cloud-only) Windows clients, hybrid users	Microsoft Entra Kerberos for hybrid identities
No identity infrastructure at all	Storage account key (full access — least preferred) or SAS
Linux, on-prem, or non-domain	NFS 4.1 (premium, VNet only, no encryption in transit — must use private endpoint) or SMB with account key

Share-level permissions use RBAC roles (Storage File Data SMB Share Reader / Contributor / Elevated Contributor); directory and file-level permissions use **Windows ACLs (NTFS)**. Both layers apply — most restrictive wins.

Azure Blob — protecting against data loss and tampering

Feature	Protects against	Notes
---------	------------------	-------

Soft delete for blobs	Accidental delete/ overwrite of blobs	Retention 1–365 days
Soft delete for containers	Accidental container deletion	Retention 1–365 days
Blob versioning	Overwrites — keeps previous versions automatically	Enables point-in-time recovery of content
Point-in-time restore	Bulk accidental changes	Requires versioning + change feed + blob soft delete; block blobs only
Immutable storage (WORM)	Tampering, ransomware, compliance	See below
Resource lock	Deletion of the storage account	Control plane only
Azure Backup for blobs	Operational and vaulted backup	Vaulted backup gives an offsite copy

Immutable storage — two policy types, applied at **container** scope or **version** scope:

- **Time-based retention policy** — data cannot be modified or deleted for N days. Starts in **unlocked** (editable, can be shortened, for testing) and must be **locked** to be compliant. Once **locked**, the retention interval can be **extended up to 5 times but never shortened**, and the policy cannot be deleted.
- **Legal hold** — a tag-based hold with no expiry; data is immutable until every legal hold tag is explicitly cleared.

Exam pattern: "Financial records must be retained unaltered for 7 years to satisfy SEC 17a-4." → **Time-based retention policy, locked.**

5. Azure SQL Database and SQL Managed

Instance security

Think in **five layers**. Exam questions almost always map to one of them.

Layer 1 — Network

- **Server-level firewall rules** (apply to all databases) and **database-level firewall rules** (more granular, evaluated first, and travel with the database).
- **"Allow Azure services and resources to access this server"** = `0.0.0.0` rule. This allows **any** Azure resource in **any** subscription — a common exam distractor for "least privilege". Turn it **off**.
- **VNet rules** (service endpoints) and **Private Endpoint** (`privatelink.database.windows.net`).
- `publicNetworkAccess = Disabled`.
- **Connection policy**: *Redirect* (lowest latency, ports 11000–11999), *Proxy* (port 1433 only), *Default*. Minimum TLS version setting.
- SQL MI: dedicated delegated subnet, mandatory NSG/route table, optional public endpoint on **port 3342**.

Layer 2 — Authentication

- **SQL authentication** (username/password) vs **Microsoft Entra authentication**.
- Set an **Microsoft Entra admin** on the logical server, then create contained users:

```
CREATE USER [analyst@contoso.com] FROM EXTERNAL PROVIDER
CREATE USER [my-app-managed-identity] FROM EXTERNAL PROVIDER
ALTER ROLE db_datareader ADD MEMBER [analyst@contoso.com]
```

- **Microsoft Entra-only authentication** — disables SQL auth entirely, including the `sa`-equivalent server admin. The hardening answer.
- Managed identity is the recommended way for an app to connect

with no password.

Layer 3 — Authorisation

Database roles (`db_owner`, `db_datareader`, `db_datawriter`), custom roles, and **row-level security (RLS)** — a security predicate function that filters rows per user (`FILTER` predicate) or blocks writes (`BLOCK` predicate).

Layer 4 — Data protection / encryption

Feature	Encrypts	Where	Protects against
TDE (Transparent Data Encryption)	Data at rest — data files, log files, backups	Server-side , transparent to apps	Physical media theft. On by default for all new Azure SQL databases
Always Encrypted	Specific columns	Client-side — data is encrypted before it leaves the app and the engine never sees plaintext	DBAs, cloud operators, and anyone with high database privileges
Always Encrypted with secure enclaves	Specific columns, but allows rich computation (range comparisons, pattern matching) and in-place encryption	Client-side keys, computation inside a trusted enclave in the engine	Same, without losing query capability

Dynamic Data Masking (DDM)	Nothing — masks results at presentation time	Query result set	Casual/unprivileged viewing only. Data is NOT encrypted.
-----------------------------------	---	------------------	---

TDE key options: *Service-managed* (default, Microsoft manages) or **customer-managed / BYOK** — a key in **Key Vault** (RSA 2048/3072/4096), which requires the server's **managed identity** with `get`, `wrapKey`, `unwrapKey`, and the vault must have **soft delete and purge protection** enabled.

Always Encrypted uses two keys: a **column encryption key (CEK)** stored encrypted in the database, wrapped by a **column master key (CMK)** stored outside SQL (Key Vault or Windows Certificate Store). Encryption types: **Deterministic** (same plaintext → same ciphertext; supports equality joins/grouping but is vulnerable to inference) vs **Randomised** (stronger, but no equality operations without enclaves).

Dynamic Data Masking — masking functions: Default, **Credit card** (XXXX-XXXX-XXXX-1234), Email (aXX@XXXX.com), Random number, **Custom string** (prefix/padding/suffix). Users in the **excluded identities** list and members of `db_owner` see unmasked data.

The distinction that gets tested: DDM only obscures the display — a user with query access can still infer values via `WHERE` clauses. If the requirement is *"the data must be protected from database administrators"*, the answer is **Always Encrypted**, never DDM or TDE.

Layer 5 — Detection and audit

- **SQL Auditing** — writes audit events to a **storage account**, **Log Analytics workspace**, or **Event Hub**. Configurable at **server level** (inherited by all DBs) or **database level**; if both are on, both run and you get duplicate logs.
- **Microsoft Defender for SQL** (part of **Defender for Databases**) provides:
 - **Vulnerability assessment** — scans for misconfigurations,

excessive permissions, unprotected sensitive data; supports a **baseline** so approved findings stop reporting.

- **Advanced Threat Protection** — alerts for **SQL injection**, potential SQL injection vulnerability, **brute-force** attacks, access from an unusual location/data center/principal, unsafe action, and data exfiltration.
 - **Data discovery and classification** — labels columns as Confidential / GDPR etc., feeding both audit logs and VA.
 - **Ledger** (Azure SQL Database) — cryptographically verifiable **tamper-evidence** using a blockchain-style hash chain, with digests optionally stored in immutable storage. The answer for "prove data has not been tampered with".
-

6. Backup security

(Officially assessed under the Defender domain's governance subsection, but it lives naturally here.)

Control	What it does
Soft delete	Deleted backup data is retained before permanent deletion. Always on for Recovery Services vaults; configurable retention (14–180 days) and can be made Always-on (irreversible)
Immutable vault	Blocks operations that would shorten retention or delete backups. Locking is irreversible.
Multi-user authorization (MUA)	Uses a Resource Guard in a different subscription/tenant so critical operations (disable soft delete, reduce retention) need a second approver via PIM . Protects against a rogue/compromised admin
Encryption with CMK	Backup data encrypted with a Key Vault key
Private endpoints	Backup traffic stays off the internet

Cross-region restore	Restore into the paired region
Alerts on critical operations	Notify on stop-protection-with-delete-data
RBAC	Backup Contributor, Backup Operator (can back up and restore but not stop protection or delete), Backup Reader

Exam pattern: "A compromised backup admin must not be able to delete backups even with Owner rights." → **Multi-user authorization with a Resource Guard** (+ immutable vault).

Rapid-fire self-test

1. Which encryption covers the **temp disk and cache with no guest CPU cost**? → **Encryption at host**
2. Which disk encryption requires `EnabledForDiskEncryption` on the Key Vault? → **ADE**
3. Which SAS is signed with Entra credentials, and its max lifetime? → **User delegation SAS, 7 days**
4. How do you make a SAS revocable without rotating keys? → **Stored access policy**
5. Which storage setting cannot be enabled after account creation? → **Infrastructure encryption**
6. Protects data from the DBA? → **Always Encrypted** (not TDE, not DDM)
7. Which SQL feature only masks results and does not encrypt? → **Dynamic Data Masking**
8. Locked time-based retention policy — can retention be shortened? → **No; extendable up to 5 times only**
9. Bastion subnet name and size? → **AzureBastionSubnet, /26**
10. Which Bastion SKU records sessions? → **Premium**
11. Which AKS setting stops `az aks get-credentials --admin`? → **Disable local accounts**
12. Which ACR SKU is needed for private endpoint, CMK, and

content trust? → **Premium**